Sandbox deployment — what the infrastructure needs

For the cloud architect. The proof of concept's infrastructure is Terraform in this repository under `infra/`. It deploys into one resource group and has been applied end to end on its own subscription. Standing it up in an organisation sandbox is the same code with a different variable file; this page lists what it needs from the subscription, so the review can happen before anything is run.

Where to look

The Terraform	`infra/*.tf` — one file per concern (`ai.tf`, `sql.tf`, `storage.tf`, `orchestration.tf`, `api.tf`, `web.tf`, `search.tf`, `integration.tf`, `rbac.tf`, `diagnostics.tf`, …)
The sandbox variable file	`infra/environments/sandbox.tfvars.example` — copy to `sandbox.tfvars`, fill the placeholders
How it is deployed and checked	`infra/README.md` (remote state, resource providers, offline `terraform validate` / `terraform test`)
What the sandbox posture changes and why	`docs/decisions/0027-sandbox-posture-and-subscription-level-terraform.md`
What runs on it and what each service is for	`lossrun-architecture.pdf` (pages 3–5 give the per-service rationale)

Everything is keyless: services talk to each other through managed identities and Entra ID. There are no secrets in variables, outputs or state inputs; the two generated secrets (SQL admin password, webhook signing key) live in Key Vault.

What the stack creates (inside the resource group)

Azure Functions (Flex Consumption) with the Durable Task Scheduler, Azure SQL (ledger and temporal tables), Storage (immutable uploads, format registry, exports), Key Vault, Microsoft Foundry (Content Understanding plus three model deployments), AI Search, Service Bus, Event Grid, Static Web Apps, Application Insights and Log Analytics, a monthly budget, a daily cost export, and managed identities with role assignments scoped to the resources above. Optional: Azure Load Testing and a mock quote system for integration tests.

The POC measured about $0.075 per 12-page loss run in AI services; the sandbox example sets a $500 monthly budget with alerts at 80 % forecast and 100 % actual.

What the subscription owner provides

1. **A resource group** (or a subscription) and a **deploying identity** — a service principal, or the developer's account — with **Contributor** and **User Access Administrator** on it. The second role is needed because the stack assigns roles to its own managed identities (Function App → Storage, Key Vault, SQL, Search, Service Bus); without it the apply stops at the first role assignment.
2. **Remote state**: a storage account for the Terraform state (`infra/bootstrap/` creates one; or an existing one, with `infra/backend.hcl.example` filled in).
3. **Resource providers registered** on the subscription. Either the deploying identity may register them (the Terraform provider does it at init), or the owner runs the one-time command in `infra/README.md` § Resource providers and the variable file sets `resource_provider_registrations = "none"`. The namespaces: AlertsManagement, CognitiveServices, Consumption, CostManagement, CostManagementExports, DurableTask, EventGrid, Insights, KeyVault, LoadTestService, ManagedIdentity, OperationalInsights, Search, ServiceBus, Sql, Storage, Web (and Security if Defender is turned on).

4 **Model quota** in a US region, Data Zone Standard deployment type: `gpt-5.2` (the learn model), `gpt-5.4-mini` (classification, delta, chat) and `text-embedding-3-large`, plus Content Understanding on the same Foundry resource. If the `gpt-5.2` quota request is still pending, `deploy_gpt52 = false` runs the learn path on `gpt-5.4-mini` until it arrives; nothing else changes.

5 **Entra ID**: an app registration for the API with six app roles (Applicant, Underwriter, UWManager, Admin, Engineer, QuoteSystem) and a SPA redirect for the workbench. Either the identity team creates it and hands over the tenant id and audience (the usual case — those become two variables), or the deploying identity holds Application Administrator and the stack creates it (`create_entra_app = true`). HTTP Basic sign-in is refused outside the POC environment by the Terraform itself.

6 **An Entra group** to be the SQL server's Entra administrator (display name and object id), so the admin role outlives one person.

7 **Two subscription-wide decisions**, which the stack deliberately leaves to the owner:
– **Defender for Cloud, AI threat protection** — a subscription-wide plan. Opt-in (`defender_ai_enabled`), default off.
– **Diagnostic logging** — on by default outside the POC: Key Vault, Storage, SQL auditing, Search, Service Bus, Foundry and the Function Apps send platform logs to the stack's Log Analytics workspace (counts toward its daily cap, `log_analytics_daily_quota_gb`).

Who runs it

Either works; the Terraform does not care:

- **The architect's team runs it.** Review `infra/`, fill `sandbox.tfvars`, `terraform init` against the remote state, `terraform plan`, review the plan, `terraform apply`. Hand back the outputs (`terraform output`): the API host, the workbench host, the Foundry endpoint and the SQL server name are what the developer needs next.
- **The developer runs it** under a deploying identity with the rights in item 1. The plan can be shared for review before apply.

Either way, before the first apply the offline checks run without any sign-in and take a minute:

```
terraform -chdir=infra fmt -check -recursive
terraform -chdir=infra init -backend=false && terraform -chdir=infra validate
terraform -chdir=infra test -var-file=environments/sandbox.tfvars.example
```

The last one plans the sandbox example against mock providers and asserts the posture: Basic auth refused, no localhost origin, diagnostics on, per-secret and per-container scopes.

After the apply

The database is deployed by the repository's own migrator (`lossrun-db deploy`, plain T-SQL changesets, rerunnable), the Function Apps and the workbench by the scripts in `infra/scripts/`, and the Search index by `lossrun chat init-index`. `next-steps-sandbox.pdf` has the order. Nothing is clicked in the portal; a manual change is captured back into Terraform or recorded in a decision record.

Not in the sandbox (production follow-ups)

Private endpoints and an API gateway in front of the API and the SPA; a Dedicated Durable Task Scheduler SKU above roughly 4,000 documents a month; Premium Search for the historical backfill. Each is listed with its reason in ADR 0027 and the governance pack.